

Ex. No 4: Analyze email headers and detect email spoofing using MHA (Mail Header Analyzer)

Date :

1. AIM

To extract, analyze, and interpret email headers to trace an email's origin, verify its authenticity protocols (SPF, DKIM, DMARC), and detect potential spoofing or phishing attempts using Mail Header Analyzer (MHA) tools.

2. SOFTWARE / TOOLS REQUIRED

- **Operating System:** Windows, Linux, or macOS
- **Email Client:** Web browser accessing Gmail, Outlook, or Yahoo
- **Analysis Tools:** MXToolbox (Online Mail Header Analyzer), WHOIS IP Lookup

3. THEORY

Every email sent over the internet contains hidden metadata known as an **Email Header**. This header tracks the email's journey from the sender's server to the recipient's inbox and contains critical routing and authentication information. Analyzing these headers helps forensic investigators verify if an email is legitimate or spoofed.

Key Authentication Protocols:

- **SPF (Sender Policy Framework):** Checks if the sender's IP address is authorized to send emails on behalf of the claimed domain.
- **DKIM (DomainKeys Identified Mail):** A cryptographic signature that verifies the email content has not been altered in transit.
- **DMARC (Domain-based Message Authentication, Reporting, and Conformance):** A policy that uses both SPF and DKIM to authenticate the email and instruct the receiving server on how to handle failures.

4. PROCEDURE & OBSERVATIONS

Step 1: Accessing the Suspicious Email

1. Log into your email account (e.g., Gmail) and locate the target email you wish to investigate (often found in the Spam or Inbox folder).
2. Open the email to view the sender details and subject line.

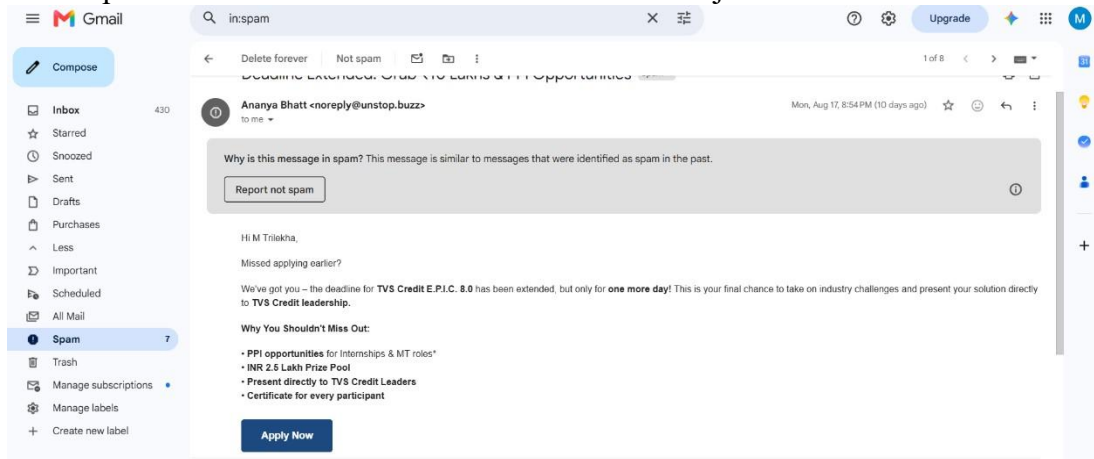


Figure 1: Viewing the suspicious email in the Gmail Spam folder

Step 2: Extracting the Raw Email Header

1. To view the hidden metadata in Gmail, click the three dots (More) in the upper right corner of the email and select **"Show original"**. (For Outlook: File > Properties > Internet headers. For Yahoo: More > View raw message).
2. Copy all the raw text provided. This text contains the Received fields, Message-ID, and authentication results.

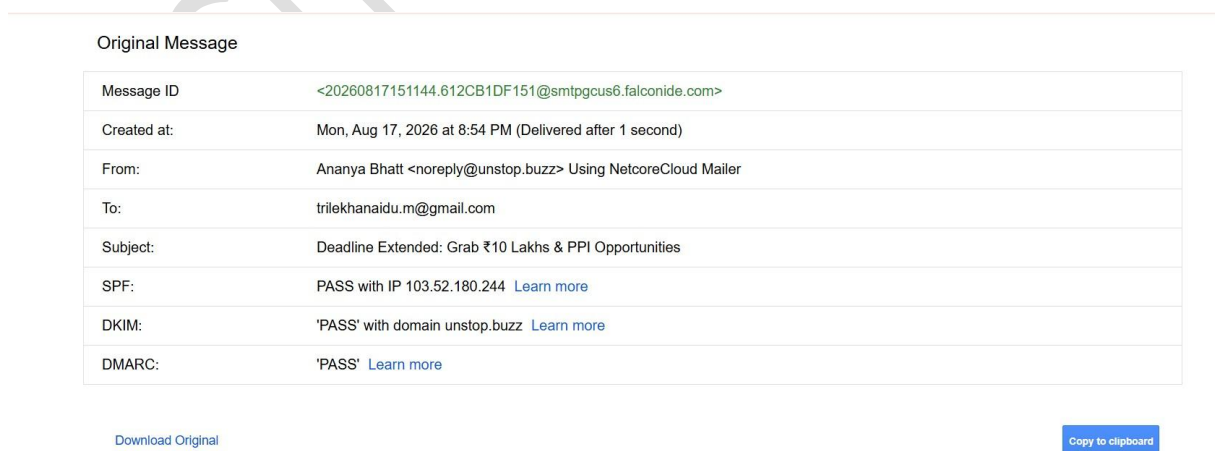


Figure 2: Extracting the original raw message and email header data

Step 3: Analyzing the Header via MXToolbox

1. Navigate to an online Mail Header Analyzer, such as **MXToolbox**.
2. Paste the copied raw header text into the analysis tool and click Analyze.
3. Review the **Delivery Information** and **Relay Information** to trace the chronological path (hops) the email took from the sending server to the receiving server. Check for unusual delays or suspicious routing.

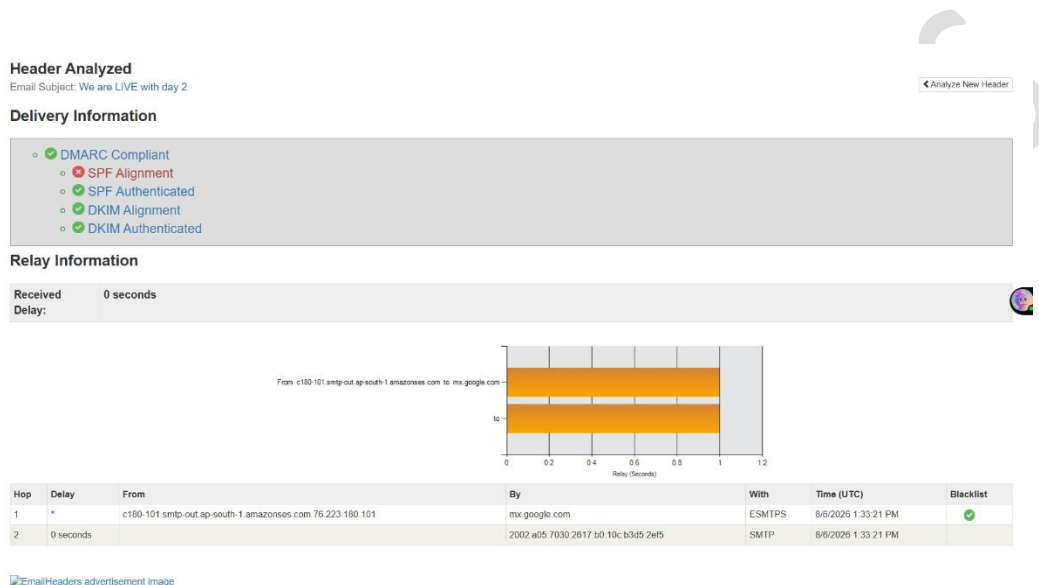


Figure 3: MHA relay analysis showing chronological hops and delivery delays

Step 4: Examining SPF, DKIM, and DMARC Results

1. Scroll down in the analyzer tool to inspect the authentication policies and Verify if the DMARC record is compliant.
2. Check the SPF and DKIM alignment to ensure the sender's IP (76.223.180.101) was genuinely authorized by the domain ().

SPF and DKIM Information

dmarc:outskill.com

Show

Solve Email Delivery Problems

v=DMARC1; p=reject; rua=mailto:349c90b7294848d1abc54efab1699dd4@dmars-reports.cloudflare.net,mailto:hi@outskill.com,mailto:admin@outskill.com,mailto:rua@dmars.brevi.com,mailto:my_dmarc_report@outskill.com

spf:ap-south-1.amazonaws.com:76.223.180.101

Hide

v=spf1 ip4:54.240.100.0/24 ip4:76.223.152.0/24 ip4:76.223.176.0/24 ip4:76.223.188.0/24 ip4:76.223.189.0/24 ip4:76.223.190.0/24 -all

Prefix	Type	Value	PrefixDesc	Description
	v	spf1		The SPF record version
+	ip4	54.240.100.0/24	Pass	Match if IP is in the given range.
+	ip4	76.223.152.0/24	Pass	Match if IP is in the given range.
+	ip4	76.223.176.0/24	Pass	Match if IP is in the given range.
+	ip4	76.223.180.0/24	Pass	Match if IP is in the given range.
+	ip4	76.223.188.0/24	Pass	Match if IP is in the given range.
+	ip4	76.223.189.0/24	Pass	Match if IP is in the given range.
+	ip4	76.223.190.0/24	Pass	Match if IP is in the given range.
-	all		Fail	Always matches. It goes at the end of your record.
I-From Domain		outskill.com		The domain used in the I-From header field.
Return-Path Domain		ap-south-1.amazonaws.com		The domain used in the Return-Path header field.

Test	Result
SPF Alignment	Domain not found in SPF
More Info	

Figure 4: Verification of SPF, DKIM, and DMARC cryptographic records

Step 5: IP Address and Hostname Verification

1. Extract the primary sending IP address identified in the Received lines (76.223.180.101).
2. Use a **WHOIS** lookup tool to identify the geographical location and ownership of the IP address.
3. Determine if the registered organization matches the expected sender.

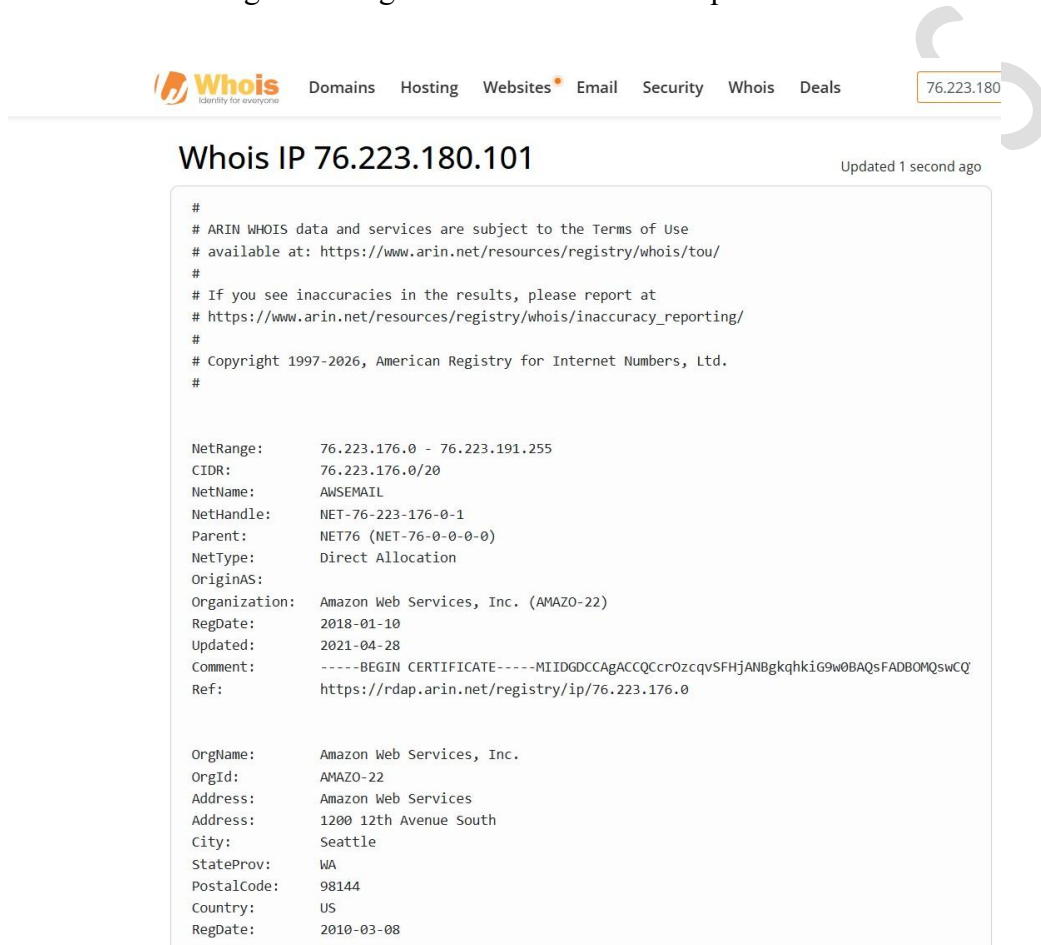


Figure 5: WHOIS IP lookup revealing the hosting organization (AWSMAIL)

5. FORENSIC FINDINGS & ANALYSIS

Based on the header analysis conducted:

- ❑ **Sender Domain:** outskill.com
- ❑ **Sending IP Address:** 76.223.180.101
- **Authentication Status:** SPF authentication PASSED, but SPF alignment FAILED. DKIM authentication and alignment PASSED, and DMARC was COMPLIANT.
- **WHOIS Verification:** The IP address belongs to AWSMAIL / Amazon Web

Services, Inc.

- **Conclusion on Spoofing:** The email header was successfully extracted and analyzed using the Mail Header Analyzer. The analysis showed that the email was sent from outskill.com through the IP address 76.223.180.101. SPF authentication passed, but SPF alignment failed, while DKIM authentication and alignment passed and DMARC was compliant. WHOIS analysis identified the IP as belonging to AWSMAIL / Amazon Web Services. Overall, the header analysis provided sufficient information to trace the email source and assess its authenticity.

6. RESULT

The email header was successfully extracted and analyzed using MXToolbox. Authentication protocols (SPF, DKIM, DMARC) and the originating IP address were manually verified, demonstrating how to trace email origins and detect potential spoofing.